

NexaPay

Plateforme de Paiement Numérique

Whitepaper Technique
Préparé pour
La Banque de Tunisie

Mai 2026

Glitch Inc — BackendGlitch Division
backendglitch.com | contact@backendglitch.com
nexapay.space | sandbox.nexapay.space

Contents

1	Présentation de NexaPay	3
1.1	URLs Publiques	3
1.2	Architecture	3
2	Sécurité et Protection des Données	4
2.1	Protection des Données Utilisateur	4
2.2	Pourquoi 3 Validateurs (BFT) ?	5
2.3	Flux d'Authentification	5
3	Processus KYC (Know Your Customer)	6
3.1	Étapes du KYC	6
3.2	Données KYC Stockées	6
3.3	Conformité Réglementaire	6
4	Parcours Utilisateur	7
4.1	Inscription (6 étapes)	7
4.2	Fonctionnalités Utilisateur	7
4.3	Dépôt d'Argent en Agence	7
5	Programme Agent / Commerçant	8
5.1	Devenir Agent	8
5.2	Capacités de l'Agent	8
5.3	Intégration Technique	8
5.3.1	Exemple API	8
6	Blockchain et Traçabilité	9
6.1	Propriétés	9
7	Pourquoi NexaPay ? — Avantages Concurrentiels	10
7.1	Comparaison avec les E-Wallets Existants	10
7.2	Ce Qui Rend NexaPay Unique	10
8	Contact	11

1 Présentation de NexaPay

NexaPay est une plateforme fintech complète conçue pour le marché tunisien. Elle combine un portefeuille numérique, une passerelle de paiement pour commerçants, et un moteur blockchain propriétaire avec consensus BFT à 3 validateurs.

1.1 URLs Publiques

nexapay.space

Page d'accueil publique

sandbox.nexapay.space

Plateforme principale (dashboard, envois, carte)

auth.nexapay.space

Authentification (login, inscription)

backend.nexapay.space

API Backend

nexapay.space/docs

Documentation API & SDK

1.2 Architecture

- **Frontend** — Next.js 16 avec routage par sous-domaines
- **Backend** — Rust/Axum avec JWT, cookies httpOnly, AES-256-GCM
- **Blockchain** — Chaîne append-only, 3 validateurs BFT, signatures Ed25519
- **Base de données** — PostgreSQL 16 + SQLite + Sled
- **SDK** — @nexapay/node-sdk sur npm

2 Sécurité et Protection des Données

La sécurité est au cœur de l'architecture NexaPay. Chaque composant a été conçu avec les meilleures pratiques de l'industrie financière.

2.1 Protection des Données Utilisateur

Données personnelles :

- Les données sensibles (CIN, numéro de téléphone, email) sont stockées dans PostgreSQL avec accès strictement contrôlé
- Les recherches de comptes ne retournent que les 4 derniers chiffres du téléphone et du CIN — jamais les données complètes
- Toutes les communications entre le navigateur et le serveur passent par HTTPS/TLS 1.3

Données bancaires :

- Les numéros de carte Visa et CVV sont chiffrés avec AES-256-GCM (standard militaire)
- Seuls les 4 derniers chiffres de la carte sont visibles — le numéro complet n'est jamais affiché
- Les clés privées Ed25519 des utilisateurs sont chiffrées avec une clé dérivée de leur PIN personnel via Argon2id
- Chaque utilisateur possède un **salt aléatoire unique** pour le hachage de son PIN — rendant les attaques par dictionnaire impossibles

Sessions et Authentification :

- Double authentification : PIN (6 chiffres) + code OTP envoyé par SMS
- Les sessions utilisent des cookies **httpOnly** (inaccessibles au JavaScript, immunisés contre le vol par XSS)
- Les tokens JWT utilisateur et administrateur sont signés avec des **clés cryptographiques distinctes**
- Les sessions peuvent être révoqués côté serveur à tout moment
- Protection contre les attaques par force brute : rate limiting par adresse IP sur toutes les routes d'authentification

Transactions et Blockchain :

- Chaque transaction est enregistrée dans un registre blockchain immuable (append-only)
- Les signatures Ed25519 garantissent la non-répudiation — aucune transaction ne peut être falsifiée
- Le consensus à 3 validateurs assure qu'aucune entité seule ne peut modifier l'état de la chaîne
- Les webhooks (notifications commerçants) sont signés avec HMAC-SHA256 pour garantir leur authenticité

2.2 Pourquoi 3 Validateurs (BFT) ?

NexaPay utilise un consensus **Byzantine Fault Tolerant** à 3 validateurs. Contrairement aux systèmes centralisés (un seul serveur) ou aux blockchains publiques (lentes et coûteuses) :

- **Aucun point de défaillance unique** — Si un validateur tombe en panne, les deux autres continuent de fonctionner
- **Validation croisée** — Chaque bloc doit être signé par les 3 validateurs avant d'être ajouté à la chaîne
- **Transactions instantanées** — Pas de minage, pas de proof-of-work. Les transferts sont appliqués en moins d'une seconde
- **Coût zéro** — Pas de frais de gas, pas de commission blockchain. Les transferts entre utilisateurs sont gratuits
- **Souveraineté** — L'infrastructure est hébergée sur nos propres serveurs, pas sur un cloud public étranger

2.3 Flux d'Authentification

1. Utilisateur entre téléphone + PIN (6 chiffres)
2. Vérification PIN avec Argon2id (sel aléatoire unique)
3. Envoi OTP 6 chiffres par SMS (Twilio)
4. Vérification OTP en temps constant (résistant aux attaques temporelles)
5. Session établie avec cookie httpOnly + JWT

3 Processus KYC (Know Your Customer)

Note : Le module KYC complet est disponible mais **désactivé pour la démo**. Les utilisateurs sont auto-vérifiés en mode sandbox. Le flux ci-dessous sera activé en production.

3.1 Étapes du KYC

1. Soumission des documents

- Photographie du **recto** et **verso** de la CIN
- Upload sécurisé avec validation (PNG, JPG, max 5 Mo)
- Stockage chiffré des documents

2. Extraction automatique (OCR)

- Nom, prénom, numéro CIN, date de naissance, date d'émission, lieu de naissance
- Croisement avec le formulaire d'inscription

3. Test de vivacité (Liveness Detection)

- Vérification via caméra (clignement, rotation tête, sourire)
- Score de correspondance faciale entre photo CIN et selfie
- Protection anti-photo et anti-vidéo

4. Vérification et approbation

- Score de vivacité > seuil requis ET données CIN correspondantes
- Compte marqué `kyc_status = verified`
- Accès complet à la plateforme

3.2 Données KYC Stockées

`kyc_cin_front_path` Chemin recto CIN

`kyc_cin_back_path` Chemin verso CIN

`kyc_face_match_score` Score correspondance faciale

`kyc_liveness_passed` Résultat test vivacité

`kyc_verified_at` Date/heure vérification

3.3 Conformité Réglementaire

Le processus est conforme avec la réglementation BCT, les directives LCB-FT, et la Loi n° 2004-63.

4 Parcours Utilisateur

4.1 Inscription (6 étapes)

1. **Téléphone** — Numéro tunisien (+216 XX XXX XXX)
2. **Informations personnelles** — Nom, prénom, email, date de naissance
3. **Identité** — Numéro CIN et date d'émission
4. **Contrat** — Signature électronique du contrat (Loi n° 2002-50)
5. **PIN** — Code 6 chiffres pour transactions
6. **Activation** — IBAN/RIB tunisien + carte Visa virtuelle + 150 TND offerts

4.2 Fonctionnalités Utilisateur

- **Portefeuille** — Solde TND, IBAN/RIB, carte Visa virtuelle
- **Envoi d'argent** — Transferts instantanés et gratuits entre utilisateurs
- **Virement bancaire** — Vers n'importe quel RIB tunisien
- **Rechargement** — Dépôt espèces en agence bancaire partenaire
- **Païement en ligne** — Checkout NexaPay chez les commerçants
- **Historique** — Transactions on-chain, vérifiables
- **Carte virtuelle** — Achats en ligne, gel/dégel

4.3 Dépôt d'Argent en Agence

1. Le client se rend dans une agence de **La Banque de Tunisie**
2. Il fournit son numéro de téléphone ou son adresse NexaPay
3. L'agent bancaire vérifie l'identité du client
4. Le dépôt en espèces est effectué au guichet
5. L'agent crédite le compte via l'interface administrateur
6. Le solde est mis à jour en temps réel

5 Programme Agent / Commerçant

5.1 Devenir Agent

1. **Candidature** — Formulaire avec nom commercial, type d'activité, matricule fiscal, adresse, volume estimé. Upload licence commerciale (PDF) et extrait RNE (PDF)
2. **Scoring** — Évaluation automatique du risque
3. **Approbation** — Automatique en sandbox, révision manuelle en production
4. **Activation** — Clé API unique, dashboard agent, limite de volume

5.2 Capacités de l'Agent

- **Liens de paiement** — Création de liens/QR codes pour accepter des paiements
- **API REST** — Intégration via API ou SDK Node.js
- **Remboursements** — Partiels ou totaux
- **Solde** — Disponible, volume brut, retraits
- **Retraits** — Transfert solde commercial → portefeuille personnel (on-chain)
- **Webhooks** — Notifications temps réel (succès/échec)
- **Statistiques** — Volume total, taux de succès, transactions du jour
- **Export** — CSV des transactions et clients

5.3 Intégration Technique

Trois modes d'intégration :

1. **No-Code** — Liens/QR codes depuis le dashboard
2. **SDK Node.js** — `npm install @nexapay/node-sdk`
3. **REST API** — Endpoints HTTP avec clé API

5.3.1 Exemple API

```
curl -X POST https://backend.nexapay.space/gateway/v1/intents \
  -H "Content-Type: application/json" \
  -H "X-API-Key: nxp_developer_CLE_API" \
  -d '{"amount":42000,"currency":"TND","description":"Cmd #42",
      "success_webhook_url":"https://maboutique.tn/hook/success"}'
```


6 Blockchain et Traçabilité

- **Consensus BFT** — 3 validateurs, quorum 3/3, signatures Ed25519
- **Registre immuable** — Toutes les transactions on-chain (append-only)
- **12 types de transactions** — Transfer, AccountCreate, EsignAccount, InvoiceAnchor, etc.
- **Ancrage** — Contrats signés et factures hashés et ancrés on-chain
- **Mempool** — 500 transactions max, expiration 5 minutes
- **Persistence** — Sled (blocs) + SQLite (snapshots)

6.1 Propriétés

- **Intégrité** — Chaque bloc référence le hash du bloc précédent
- **Non-répudiation** — Signatures Ed25519 sur transactions utilisateur
- **Auditabilité** — Toute transaction vérifiable indépendamment
- **Résilience** — 3 validateurs redondants

7 Pourquoi NexaPay ? — Avantages Concurrentiels

7.1 Comparaison avec les E-Wallets Existants

	E-Wallets Traditionnels	NexaPay
Infrastructure	Serveur centralisé unique	3 validateurs BFT redondants
Vitesse transferts	1–3 jours ouvrés (virement)	Instantané (<1 seconde)
Frais transferts	0.5–2% par transaction	Gratuit entre utilisateurs
Traçabilité	Base de données interne	Blockchain immuable vérifiable
IBAN/RIB	Dépend de la banque partenaire	Généré automatiquement
Carte virtuelle	Parfois disponible	Visa virtuelle incluse
API Commerçants	Limitée ou absente	REST API + SDK npm
Webhooks	Rare	Signés HMAC-SHA256 avec retry
KYC	Manuel (agence)	Automatisé (OCR + liveness)
Contrat électronique	Papier	Signé + ancré blockchain (Loi 2002-50)
Chiffrement	Variable	AES-256-GCM bout en bout

7.2 Ce Qui Rend NexaPay Unique

1. **Blockchain privée à 3 validateurs** — Ni centralisé (risque de panne unique), ni blockchain publique (lente et chère). Un compromis idéal pour la finance : rapidité, sécurité, et coût zéro.
2. **IBAN/RIB tunisien généré automatiquement** — Chaque compte NexaPay reçoit un IBAN et RIB tunisien. Les virements bancaires standards fonctionnent sans adaptation.
3. **Double rôle utilisateur/commerçant** — Un même compte peut être portefeuille personnel ET passerelle de paiement. Pas besoin de deux applications distinctes.
4. **Ancrage blockchain des documents** — Les contrats d'ouverture de compte et les factures sont hashés et enregistrés on-chain. Toute autorité peut vérifier l'authenticité d'un document de manière indépendante.
5. **Conçu pour la Tunisie** — Conforme à la réglementation BCT, formats tunisiens (CIN, RIB 20 chiffres, numéros +216), interface en français, support des dépôts en espèces en agence.
6. **Intégration simple pour les commerçants** — 3 modes : liens de paiement (no-code), SDK npm, ou REST API. Le commerçant choisit selon ses capacités techniques.

8 Contact

Glitch Inc — BackendGlitch Division

Site web backendglitch.com
Email contact@backendglitch.com
GitHub github.com/Samer-Gassouma/NexaPay
SDK npm npmjs.com/package/@nexapay/node-sdk

Landing nexapay.space
Sandbox sandbox.nexapay.space
API Backend backend.nexapay.space
Documentation nexapay.space/docs

Merci de votre attention.

Disponible pour démonstration en direct et questions techniques.

Glitch Inc — BackendGlitch Division © 2026